FinTechathon 2026: Security & Threat Self-Assessment

Formal Threat Modeling, RBAC Verification & Safeguard Audit Report

1. Executive Security Summary

SME Finance Copilot processes mission-critical corporate accounting, tax filings, and banking loan packets. The security architecture adheres to OWASP Top 10 API Security guidelines, implementing defense-in-depth across network gateways, cryptographic sessions, relational multi-tenancy, and autonomous AI execution guardrails.

2. Threat Analysis & Implemented Controls

Threat Category	OWASP / Risk	Attack Vector	Implemented Control	Verification Test
Broken Object Level Auth (BOLA)	API1:2023	Passing foreign business_id in URL/body	Mandatory tenant membership verification on all DB queries (HTTP 403)	test_isolation.py (PASS)
Broken Authentication	API2:2023	Forging X-User-ID or X-Role headers	Client headers ignored; identity strictly derived from signed HMAC SHA-256 tokens	test_api_security.py (PASS)
Formula Injection (CSV DDE)	CWE-1236	Customer/Item strings with =, +, -, @	Automatic leading quote prefixing (') on all CSV export cells	test_report_storage.py (PASS)
Adversarial AI Jailbreak	LLM01:2025	DAN, system override prompts	Regex/heuristic guardrails reject prompts prior to RAG/LLM invocation	test_rag_pipeline.py (PASS)
Autonomous Ledger Corruption	LLM08:2025	Voice AI directly modifying ledger	Consequential action confirmation barrier with single-use signed tokens	test_voice_ai.py (PASS)
Malicious File Uploads	CWE-434	Uploading .exe/.sh or path traversal	MIME validation, magic-byte inspection, sanitized deterministic filenames	test_api_security.py (PASS)

3. Role-Based Access Control (RBAC) & Least Privilege

The application models 7 distinct roles (Owner, Manager, Accountant, Sales, Inventory, Auditor, Super Admin) across 22 atomic permissions. Critical boundaries verified during evaluation:

- **Platform Admin Boundary:** Standard users attempting to query `/app/admin` or `/api/admin/*` receive HTTP 403 Forbidden unconditionally.
- **Auditor Isolation:** Auditors possess read-only permissions across ledger and compliance logs; write endpoints (`POST /api/finance/sales`, `POST /api/inventory/items`) are strictly blocked.
- **Store Personnel Restrictions:** Sales officers cannot view balance sheets or modify inventory cost prices.

4. Secrets Management & Repository Hygiene

• **Zero Secrets in Git:** `.gitignore` strictly excludes `.env`, `*.db`, `*.db-wal`, `var/backups/`, and `var/exports/`.
• **Sanitized Error Disclosures:** Database exceptions and internal stack traces are captured server-side in logging streams; external API responses receive sanitized HTTP error payloads without leaking database schemas.
• **WAL-Safe Backup Verification:** Database backups utilize SQLite's atomic online backup API accompanied by SHA-256 manifests.